ONE-PAGE BRIEF

Post-quantum cryptography review: metamask-extension @ d2db7ee9a19b

Client: MetaMask (Consensys) — public repository (passive review) · Source: github.com/MetaMask/metamask-extension, commit `d2db7ee9a19b` · Reviewed: 2026-10-28 18:07 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
0 Critical **0** High **4** Medium
0 Low **2** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Medium QSI-2026-05545	**Quantum-vulnerable ECDSA: transaction and message signing (1 file(s))** preliminary What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains...
Medium QSI-2026-05544	**Quantum-vulnerable ECDSA: role not determined (10 file(s))** preliminary What to do: Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/composite form...
Medium QSI-2026-05546	**Non-cryptographic RNG near security-sensitive identifiers in app/scripts/sidepanel/background.ts** preliminary What to do: Use a CSPRNG (secrets, crypto.getRandomValues, crypto/rand).
Medium QSI-2026-05547	**Non-cryptographic RNG near security-sensitive identifiers in shared/lib/delegation/delegation.ts** preliminary What to do: Use a CSPRNG (secrets, crypto.getRandomValues, crypto/rand).

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	ECDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium role not determined	ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)...

Static review of source code and manifests; files analysed: 4873. No requests were sent to the owner's systems.

Full report, content SHA-256: `3e15a6641b388b9e7614f91ad6e3c8e06e6e7466bceec4cd6c98668bd45c47ca`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.